RELATÓRIO TÉCNICO DE VULNERABILIDADES

CVEs recentes do Node.js

Análise detalhada: junho a outubro de 2026

Inclui a RCE no decodificador Brotli (CVE-2026-111497)

Data de referência: 22 de outubro de 2026
Escopo: Node.js 22.x, 24.x e 26.x — 33 CVEs analisadas em detalhe (+ março/2026 em apêndice)
Fontes primárias: Node.js Security Releases (nodejs.org/en/blog/vulnerability),
notas de versão v24.22.1 e imprensa especializada

Documento de estudo. Os avisos do Node.js publicam descrições curtas e sem CVSS; as explicações aqui seguem o texto oficial e indicam quando um detalhe vem de fonte secundária. Confirme sempre nas fontes originais.

Sumário

1. Sumário executivo **3**

2. Conceitos e versões **5**

3. Lançamento de 21/10/2026 **6**

3.1 CVE-2026-111497 — RCE no decodificador Brotli . . . 6

3.2 CVE-2026-105482 — dns.resolve trunca nomes com NUL . . . 7

3.3 CVE-2026-105483 — bypass de hostname TLS com dígitos fullwidth . . . 7

3.4 CVE-2026-106069 — bypass de hostname TLS com IP “frouxo” . . . 8

3.5 CVE-2026-105481 — keep-alive aceita resposta anterior à requisição . . . 8

3.6 CVE-2026-106072 — SAN DNS autentica IPv4 não canônico . . . 9

3.7 CVE-2026-106074 — entropia repetida em snapshots e SEAs . . . 9

3.8 CVEs de gravidade baixa de outubro . . . 10

3.9 Comprometimento da CA intermediária eMudhra . . . 10

4. Lançamento de 29/07/2026 **11**

4.1 CVE-2026-56846 — HTTP/2 burla maxSessionMemory . . . 11

4.2 CVE-2026-56848 — use-after-free no HTTP/2 . . . 11

4.3 CVE-2026-58043 — Permission Model concede acesso a mais . . . 12

4.4 CVE-2026-56850 — reuso de identidade mTLS entre PFX . . . 12

4.5 CVE-2026-58040 — reuso de sessão TLS pula hostname . . . 13

4.6 CVE-2026-58041 — node:sqlite repete escritas . . . 13

4.7 CVE-2026-58042 — dns.resolveAny() aborta o processo . . . 14

4.8 CVE-2026-58045 — zlib síncrono quebra com tamanho falsificado . . . 14

4.9 CVEs de gravidade baixa de julho . . . 14

5. Lançamento de 18/06/2026 **16**

5.1 CVE-2026-48933 — WebCrypto AES: integer overflow . . . 16

5.2 CVE-2026-48618 — ponto Unicode burla curinga TLS . . . 16

5.3 CVEs de gravidade média de junho . . . 17

5.4 CVEs de gravidade baixa de junho . . . 17

6. Padrões que se repetem **18**

7. Recomendações práticas **18**

Apêndice A — Lançamento de 24/03/2026 (resumo) **20**

Fontes de pesquisa **20**

1. Sumário executivo

Este relatório analisa as vulnerabilidades corrigidas pelo projeto Node.js nos três lançamentos de segurança mais recentes — **18/06, 29/07 e 21/10/2026** — e explica, para cada CVE, **o que ela identifica**, **o impacto** e **como corrigir ou mitigar**. O lançamento de 24/03/2026 aparece resumido no apêndice. Ao todo são 33 CVEs detalhadas.

O destaque é a **CVE-2026-111497**, corrigida em 21/10/2026: uma **escrita fora dos limites no decodificador Brotli** embutido no Node.js que, segundo o aviso oficial, **permite execução remota de código**. Ela afeta as três linhas suportadas (22, 24 e 26). Como o `fetch()` nativo descomprime automaticamente respostas `Content-Encoding: br`, qualquer aplicação que baixe conteúdo de servidores não confiáveis pode estar exposta. No mesmo lançamento saíram três bypasses de verificação de hostname TLS e uma truncagem de nomes no DNS, todos de gravidade alta.

Principais conclusões

- **Atualize para 22.23.4, 24.22.1 ou 26.12.1** (ou posterior). O aviso de outubro não traz contornos; a atualização é a única correção.
- **Node.js 20 e 25 estão em fim de vida** e não recebem correções. O projeto afirma que versões EOL são sempre afetadas pelos lançamentos de segurança.
- **Reiniciar é obrigatório:** o processo em execução mantém o binário antigo na memória. Imagens Docker, SEAs (Single Executable Applications) e snapshots precisam ser **reconstruídos**.
- **TLS é o tema dominante:** 8 das 33 CVEs envolvem verificação de hostname, SNI, reuso de sessão ou identidade mTLS. O padrão se repete: normalizações diferentes do mesmo endereço (maiúsculas, dígitos Unicode, byte NUL, IP não canônico) entre o resolvedor e o verificador de certificado.
- **O Permission Model** (`--permission`) teve 8 CVEs de bypass. Ele ainda não deve ser tratado como fronteira de segurança completa.
- `npm audit` **não detecta** nenhuma destas falhas, porque ele analisa dependências do projeto, não o runtime.
- Até 22/10/2026 não há relato de exploração ativa nem CVSS publicado; as CVEs de outubro ainda constavam como RESERVED no CVE.org, segundo a imprensa.

Visão geral das CVEs analisadas

CVE	Componente	Tipo de falha	Grav.	Lançamento
CVE-2026-111497	zlib / Brotli	Escrita fora dos limites → RCE	Alta	21/10
CVE-2026-105482	dns	Nome truncado no byte NUL	Alta	21/10
CVE-2026-105483	tls	Bypass de hostname com dígitos fullwidth	Alta	21/10
CVE-2026-106069	tls	Bypass de hostname com IP “frouxo”	Alta	21/10
CVE-2026-105481	http (Agent)	Resposta enviada antes da requisição aceita	Média	21/10
CVE-2026-106072	tls	SAN DNS autentica IPv4 não canônico	Média	21/10
CVE-2026-106074	crypto	Entropia repetida em snapshots/SEAs	Média	21/10
CVE-2026-106070	ZipFile	Prefixo controlado após falha de validação	Baixa	21/10
CVE-2026-106071	Permission Model	Over-grant via busca radix com curinga	Baixa	21/10
CVE-2026-106073	Permission Model	Bypass via fs.realpathSync	Baixa	21/10
CVE-2026-56846	http2	Cabeçalhos retidos burlam maxSessionMemory	Alta	29/07
CVE-2026-56848	http2 (nghttp2)	Envio reentrante → use-after-free	Alta	29/07
CVE-2026-58043	Permission Model	Casamento de prefixo concede acesso a mais	Alta	29/07
CVE-2026-56850	https (Agent)	Reuso de identidade mTLS entre PFX	Média	29/07
CVE-2026-58040	https (Agent)	Reuso de sessão pula verificação de hostname	Média	29/07
CVE-2026-58041	node:sqlite	Iterador repete escritas	Média	29/07
CVE-2026-58042	dns	resolveAny() aborta com >256 registros A	Média	29/07
CVE-2026-58045	zlib	Crash com byteLength falsificado	Média	29/07
CVE-2026-56847	Permission Model	trace_events grava fora da allowlist	Baixa	29/07
CVE-2026-58039	Permission Model	process.report grava fora da allowlist	Baixa	29/07
CVE-2026-58044	http (llhttp)	Truncagem de cabeçalhos → request smuggling	Baixa	29/07
CVE-2026-48933	WebCrypto	Integer overflow AES → abort do processo	Alta	18/06
CVE-2026-48618	tls	Ponto Unicode → bypass de profundidade de curinga	Alta	18/06
CVE-2026-48615	http (proxy)	Credenciais do proxy em mensagem de erro	Média	18/06
CVE-2026-48619	http2 (cliente)	Frames ORIGIN ilimitados → OOM	Média	18/06
CVE-2026-48937	http2 (servidor)	Sessão não limpa após GOAWAY	Média	18/06
CVE-2026-48928	tls (SNI)	SNI com maiúsculas → bypass de mTLS	Média	18/06
CVE-2026-48930	dns/net	Hostname com NUL → troca silenciosa de autoridade	Média	18/06
CVE-2026-48934	tls	Reuso de sessão com outro servername	Média	18/06
CVE-2026-48617	Permission Model	Bypass via process.report.writeReport()	Baixa	18/06
CVE-2026-48935	Permission Model	Bypass via FileHandle.utimes()	Baixa	18/06
CVE-2026-48936	Permission Model	Socket Unix ignora restrição de rede	Baixa	18/06
CVE-2026-48931	http (Agent)	Envenenamento da fila de respostas (TOCTOU)	Baixa	18/06

O Node.js classifica a gravidade como Alta/Média/Baixa e não publica pontuação CVSS nos avisos. Todas as datas são de 2026.

2. Conceitos e versões

Linhas de versão do Node.js (situação em outubro de 2026)

Linha	Situação	Versão corrigida mais recente
26.x	Current (versão mais nova)	26.12.1
24.x	LTS ativa (“Latest LTS”)	24.22.1
22.x	LTS de manutenção	22.23.4
20.x e 25.x	Fim de vida (EOL) — sem correções	Migrar para 22 ou 24

Para verificar a versão: `node -v` ou `node -p process.versions.node`. Em containers, verifique a imagem base (ex.: `node:24-alpine`).

Glossário

Termo	Significado
Brotli	Algoritmo de compressão do Google usado em HTTP (`Content-Encoding: br`). O Node.js embute a biblioteca e a expõe em `node:zlib`.
SAN / CN	Subject Alternative Name e Common Name: campos do certificado que dizem para quais nomes ou IPs ele vale. A verificação de hostname compara o destino com esses campos.
SNI	Server Name Indication: o cliente informa no handshake TLS o nome que quer acessar, para o servidor escolher o certificado certo.
mTLS	TLS mútuo: o cliente também apresenta certificado (ex.: arquivo PFX) e o servidor o autentica.
Reuso de sessão TLS	Otimização que retoma uma sessão TLS anterior sem repetir o handshake completo — se mal controlada, pula verificações.
Keep-alive / http.Agent	O Agent mantém conexões abertas e as reaproveita para várias requisições, em fila.
Request smuggling	Cliente e servidor (ou proxy e backend) discordam sobre onde termina uma requisição, permitindo “contrabandear” uma segunda requisição escondida.
Permission Model	Recurso ativado com `--permission` que restringe o acesso do processo a arquivos (`--allow-fs-read/write`), rede, processos filhos etc.
SEA / snapshot	Single Executable Application (app empacotado num executável) e snapshot de inicialização (estado de memória pré-carregado para iniciar mais rápido).
Byte NUL	Caractere de código 0. Em C ele marca o fim de uma string; se o JavaScript o aceita no meio de um nome, o código C “corta” o nome ali.
Fullwidth	Dígitos Unicode de largura total (faixa U+FF10 a U+FF19, visualmente iguais a 0–9) que se parecem com os números ASCII mas são caracteres diferentes.
DoS / OOM / UAF	Negação de serviço; falta de memória; use-after-free (uso de memória já liberada).

3. Lançamento de 21/10/2026

Versões corrigidas: **22.23.4, 24.22.1 e 26.12.1**. Dez CVEs (4 altas, 3 médias, 3 baixas) e atualizações de dependências: c-ares 1.34.9, undici (7.30.1 na linha 24), OpenSSL 3.5.9 (22 e 24), SQLite (22), certificados raiz NSS 3.131.1 e um bloqueio de certificados ligado ao **comprometimento de uma CA intermediária da eMudhra** (seção 3.9). O aviso oficial traz apenas os títulos das CVEs (com exceção da Brotli); os nomes dos commits nas notas da v24.22.1 ajudam a entender cada correção.

Segundo a cobertura da imprensa, vários commits de correção trazem a anotação “Assisted-by” citando ferramentas de IA, com revisão humana de cada mudança.

3.1 CVE-2026-111497 — RCE no decodificador Brotli

CVE-2026-111497	GRAVIDADE ALTA
Título oficial	Brotli decoder out-of-bounds write permits remote code execution
Componente	deps/brotli (exposto via node:zlib, fetch, body parsers)
Linhas afetadas	26.x, 24.x, 22.x
Corrigido em	22.23.4 · 24.22.1 · 26.12.1
Relator / correção	mcollina / aduh95
Commit da correção	deps: brotli: cherry-pick 0ed4268a4401abcb44720963 (Evgenii Kliuchnikov); src: expose BROTLI_DECODER_ERROR_FORMAT_BLOCK_SWITCH

O que identifica

O decodificador Brotli embutido no Node.js trata incorretamente fluxos comprimidos malformados e **escreve fora dos limites do buffer** de saída. Escrita fora dos limites é a classe de falha mais perigosa em código C/C++, porque permite sobrescrever estruturas vizinhas na memória — por isso o aviso fala em execução remota de código. A correção é um cherry-pick do projeto Brotli do Google; o commit adicional expõe o novo código de erro `BROTLI_DECODER_ERROR_FORMAT_BLOCK_SWITCH`, o que indica que o problema estava no tratamento das trocas de bloco (block switch) do formato.

Por onde chega o dado malicioso (segundo análises de terceiros): o `fetch()` nativo descomprime automaticamente respostas `Content-Encoding: br`; o body parser do Express 5 faz o mesmo com requisições recebidas; também foram citados a otimização de imagens do Next.js e aplicações que fazem scraping ou preview de URLs não confiáveis. Qualquer chamada direta a `zlib.brotliDecompress()` sobre dados externos também é caminho.

Impacto

Execução remota de código no processo Node.js, com os privilégios dele. O aviso não informa pré-requisitos nem relata exploração ativa; a imprensa cita que a Vercel afirmou que pesquisadores demonstraram vazamento de memória e execução de comandos em versões sem correção.

Correção e mitigação

Atualizar. Em distribuições que ligam o Node.js a uma libbrotli do sistema, a correção pode vir pelo pacote brotli — verifique com `ldd "$(command -v node)" | grep -i brotli`. Até atualizar: no proxy reverso, remova `br` do `Accept-Encoding` das requisições de saída e rejeite `Content-Encoding: br` em requisições de entrada se a aplicação não precisar disso (medida paliativa, não oficial).

3.2 CVE-2026-105482 — dns.resolve trunca nomes com NUL

CVE-2026-105482	GRAVIDADE ALTA
Título oficial	dns.resolve truncates names containing NUL char
Componente	dns (dns.resolve*)
Linhas afetadas	26.x, 24.x, 22.x
Corrigido em	22.23.4 · 24.22.1 · 26.12.1
Relator / correção	hasanfleyah / jasnell

O que identifica

Um nome contendo um byte NUL (`\0`) é passado do JavaScript para o código C (c-ares), que trata o NUL como fim da string. Assim, `'api.permitido.com\0.atacante.com'` pode ser validado pela aplicação de um jeito e resolvido de outro. O commit de correção é “dns: validate resolve inputs for null bytes”. É uma regressão do mesmo padrão da CVE-2026-48930 de junho, agora no módulo dns.

Impacto

Burla de listas de permissão (allowlists) baseadas em hostname — por exemplo, em proteções contra SSRF — fazendo a consulta DNS ir para um nome diferente do validado.

Correção e mitigação

Atualizar. Paliativo: validar e rejeitar entradas com caracteres de controle (`/[\x00-\x1f]/`) antes de qualquer resolução ou requisição.

3.3 CVE-2026-105483 — bypass de hostname TLS com dígitos fullwidth

CVE-2026-105483	GRAVIDADE ALTA
Título oficial	TLS certificate hostname bypass when the IP is written fullwidth digits
Componente	tls (verificação de hostname / normalização de IP)
Linhas afetadas	26.x, 24.x
Corrigido em	22.23.4 · 24.22.1 · 26.12.1
Relator / correção	hasanfleyah / jasnell
Commit da correção	tls: fix ip normalization regression

O que identifica

Endereços IPv4 escritos com dígitos Unicode de largura total (ex.: “127.0.0.1” digitado com os caracteres U+FF11, U+FF12, U+FF17 etc. no lugar de 1, 2, 7) eram normalizados de forma diferente pelo resolvedor e pelo verificador de certificado: a conexão ia para um IP e a verificação era feita contra outro valor. O commit se chama “fix ip normalization regression”, ou seja, uma correção anterior introduziu o problema.

Impacto

Um certificado válido para um nome pode ser aceito para uma conexão que vai a outro destino — base para ataques man-in-the-middle. O próprio commit chama o bug de difícil de explorar, embora o aviso o classifique como alto.

Correção e mitigação

Atualizar. Paliativo: normalizar/validar destinos informados pelo usuário com `net.isIP()` e rejeitar caracteres não ASCII em hosts.

3.4 CVE-2026-106069 — bypass de hostname TLS com IP “frouxo”

CVE-2026-106069	GRAVIDADE ALTA
Título oficial	TLS certificate hostname bypass when the host loosely resolves to an IP address
Componente	tls
Linhas afetadas	26.x, 24.x, 22.x
Corrigido em	22.23.4 · 24.22.1 · 26.12.1
Relator / correção	anagnorisis2peripeteia / mcollina
Commit da correção	tls: reject non-canonical IP addresses (corrige também a CVE-2026-106072)

O que identifica

Formas não canônicas de IPv4 — como `127.1`, octal (`0177.0.0.1`) ou decimal inteiro — são aceitas pelo resolvedor do sistema como IP, mas o verificador TLS as tratava como nome de domínio. A verificação de certificado e o destino real da conexão divergiam.

Impacto

Um atacante que controle o destino digitado pelo usuário (comum em webhooks, integrações e ferramentas internas) pode fazer a aplicação aceitar um certificado que não deveria valer para aquele destino.

Correção e mitigação

Atualizar (o Node.js passa a rejeitar IPs não canônicos). Nunca usar `rejectUnauthorized: false` ou `NODE_TLS_REJECT_UNAUTHORIZED=0` como contorno.

3.5 CVE-2026-105481 — keep-alive aceita resposta anterior à requisição

CVE-2026-105481	GRAVIDADE MÉDIA
Título oficial	Keep-alive socket processes a response that was written before the request was sent
Componente	http (http.Agent / keep-alive)
Linhas afetadas	26.x, 24.x, 22.x
Corrigido em	22.23.4 · 24.22.1 · 26.12.1
Relator / correção	hasanfleyah / jasnell
Commit da correção	http: ensure agent data guard works without I/O

O que identifica

Ao reaproveitar uma conexão keep-alive, o Node.js deveria descartar qualquer dado que o servidor enviou *antes* de a nova requisição sair. A proteção existente (“data guard”) só funcionava quando havia operação de I/O; sem ela, dados enviados antecipadamente eram lidos como resposta da próxima requisição. É a continuação da CVE-2026-48931 de junho.

Impacto

Um servidor malicioso ou comprometido pode “plantar” uma resposta que será entregue à próxima requisição feita na mesma conexão — inclusive de outro usuário, num serviço intermediário.

Correção e mitigação

Atualizar. Paliativo: desativar keep-alive (`agent: new http.Agent({ keepAlive: false })`) para destinos não confiáveis.

3.6 CVE-2026-106072 — SAN DNS autentica IPv4 não canônico

CVE-2026-106072	GRAVIDADE MÉDIA
Título oficial	Improper certificate validation for non-canonical IPv4 hostnames allows DNS SANs to authenticate IP endpoints
Componente	tls
Linhas afetadas	26.x, 24.x, 22.x
Corrigido em	22.23.4 · 24.22.1 · 26.12.1
Relator / correção	br41ny / mcollina
Commit da correção	tls: reject non-canonical IP addresses

O que identifica

Variação da 3.4: quando o destino é um IPv4 não canônico, ele era comparado com as entradas **DNS** do SAN do certificado, em vez das entradas de **IP**. Um certificado emitido para o nome `127.1` (possível em PKI privada) autenticaria o endereço IP 127.0.0.1.

Impacto

Autenticação de endpoints IP com certificados que não deveriam valer para eles.

Correção e mitigação

Atualizar.

3.7 CVE-2026-106074 — entropia repetida em snapshots e SEAs

CVE-2026-106074	GRAVIDADE MÉDIA
Título oficial	crypto.randomUUID() and randomInt() entropy caches are saved into user-land startup snapshots and SEAs, so every process repeats the same values
Componente	crypto
Linhas afetadas	26.x, 24.x, 22.x
Corrigido em	22.23.4 · 24.22.1 · 26.12.1
Relator / correção	gesposito / panva
Commit da correção	crypto: reset random caches across snapshots

O que identifica

Para ganhar desempenho, `crypto.randomUUID()` e `crypto.randomInt()` pré-geram um lote de bytes aleatórios em cache. Se a aplicação é empacotada como snapshot de inicialização ou SEA, esse cache era **gravado dentro do artefato**. Todo processo iniciado a partir dele começa com os mesmos bytes e gera os mesmos “aleatórios”.

Impacto

UUIDs, tokens, IDs de sessão ou valores sorteados previsíveis e repetidos entre instâncias. Só afeta quem usa snapshots/SEAs.

Correção e mitigação

Atualizar e reconstruir os snapshots e SEAs — só atualizar o Node.js não corrige artefatos já gerados. Revogar tokens gerados por artefatos afetados.

3.8 CVEs de gravidade baixa de outubro

CVE	Título oficial	Linhas	O que identifica
CVE-2026-106070	ZipFile returns attacker-controlled prefix bytes after failed ZIP header validation	26.x	No leitor ZIP novo da linha 26, quando a validação do cabeçalho falha, a API ainda devolve bytes iniciais controlados pelo atacante, que o código pode processar como se fossem válidos. Relator startimeash; correção mcollina.
CVE-2026-106071	Permission Model filesystem over-grant via wildcard radix lookup	26.x	Permissões com curinga (`--allow-fs-read=/app/*`) eram buscadas na árvore radix de forma que concedia acesso a caminhos além do pretendido. Relator malikhamzaiqbal; correção jasnell.
CVE-2026-106073	Permission Model bypass with fs.realpathSync	26.x, 24.x, 22.x	`fs.realpathSync` não consultava o Permission Model, permitindo testar a existência e resolver caminhos fora das pastas liberadas. Repete a CVE-2026-21715 de março (variante `.native`). Relator 0xoroot; correção RafaelGSS.

3.9 Comprometimento da CA intermediária eMudhra

O aviso oficial lista entre as dependências atualizadas “ca-cert (eMudhra Intermediate CA Compromise)” nas três linhas, e as notas da v24.22.1 incluem o commit “tls: reject chains containing blocked public keys” e a atualização dos certificados raiz para o NSS 3.131.1. Na prática, o Node.js passa a **recusar cadeias de certificado que contenham chaves públicas bloqueadas** ligadas a intermediárias comprometidas da autoridade certificadora eMudhra.

Segundo a imprensa, os navegadores bloquearam as chaves em poucas horas; como o Node.js não consulta listas de revogação em tempo real, a solução foi embutir uma lista fixa de bloqueio. Efeito colateral: conexões que dependem dessas intermediárias passam a falhar após a atualização — se uma integração quebrar com erro de certificado, verifique a cadeia do servidor antes de culpar a aplicação.

4. Lançamento de 29/07/2026

Versões corrigidas: **22.23.2, 24.18.1 e 26.5.1**. Onze CVEs (3 altas, 5 médias, 3 baixas), mais undici (8.9.0, 7.29.0, 6.28.0) e llhttp 9.4.3. O lançamento, previsto para 28/07, foi adiado duas vezes — para testes adicionais e por problemas de infraestrutura.

4.1 CVE-2026-56846 — HTTP/2 burla maxSessionMemory

CVE-2026-56846	GRAVIDADE ALTA
Título oficial	HTTP/2 retained headers can bypass maxSessionMemory limits
Componente	http2
Linhas afetadas	24.x, 22.x (conforme o aviso)
Corrigido em	22.23.2 · 24.18.1 · 26.5.1
Relator / correção	leduckhuong / mcollina

O que identifica

A opção `maxSessionMemory` limita quanta memória uma sessão HTTP/2 pode consumir. Blocos de cabeçalhos que ficam **retidos** (aguardando processamento) não eram contabilizados nesse limite, então um cliente pode acumular cabeçalhos até esgotar a memória do servidor.

Impacto

Esgotamento remoto de memória (DoS) em servidores HTTP/2 Node.js expostos.

Correção e mitigação

Atualizar. Paliativo: terminar HTTP/2 num proxy (nginx, Envoy) e falar HTTP/1.1 com o Node.js, ou limitar memória do container para reinício rápido.

4.2 CVE-2026-56848 — use-after-free no HTTP/2

CVE-2026-56848	GRAVIDADE ALTA
Título oficial	HTTP/2 re-entrant send can cause heap-use-after-free
Componente	http2 (nghttp2)
Linhas afetadas	26.x, 24.x, 22.x
Corrigido em	22.23.2 · 24.18.1 · 26.5.1
Relator / correção	hahahkim / mcollina

O que identifica

A função `nghttp2_session_mem_send()` podia ser chamada de forma **reentrante** enquanto `nghttp2_session_mem_recv()` ainda executava. O envio liberava estruturas que o recebimento continuava usando — um use-after-free no heap.

Impacto

Corrupção de memória com crash do processo; use-after-free é uma classe que, em tese, pode evoluir para execução de código, embora o aviso não afirme isso.

Correção e mitigação

Atualizar. Mesmo paliativo do item 4.1 (terminar HTTP/2 no proxy).

4.3 CVE-2026-58043 — Permission Model concede acesso a mais

CVE-2026-58043	GRAVIDADE ALTA
Título oficial	Permission Model path matching can over-grant filesystem access
Componente	Permission Model (árvore radix de caminhos)
Linhas afetadas	26.x, 24.x, 22.x
Corrigido em	22.23.2 · 24.18.1 · 26.5.1
Relator / correção	sy2n0 / RafaelGSS

O que identifica

O Permission Model guarda os caminhos liberados numa árvore radix (por prefixo). O tratamento da fronteira do prefixo estava errado: liberar `/app/data` podia liberar também `/app/data-secreto`, porque um é prefixo textual do outro.

Impacto

Leitura e escrita não autorizadas fora da allowlist de `--allow-fs-*` — só relevante para quem usa `--permission`.

Correção e mitigação

Atualizar. Não usar o Permission Model como única barreira; combinar com usuário sem privilégios e permissões do sistema de arquivos/containers.

4.4 CVE-2026-56850 — reuso de identidade mTLS entre PFX

CVE-2026-56850	GRAVIDADE MÉDIA
Título oficial	HTTPS Agent can reuse mTLS identities across PFX certificates
Componente	https (Agent)
Linhas afetadas	26.x, 24.x, 22.x
Corrigido em	22.23.2 · 24.18.1 · 26.5.1
Relator / correção	yottt / RafaelGSS

O que identifica

O `https.Agent` gera uma chave para decidir se pode reaproveitar uma conexão. Quando o certificado de cliente é passado como **array de objetos PFX**, configurações diferentes geravam a mesma chave, e uma requisição configurada com o certificado B podia sair pela conexão já autenticada com o certificado A.

Impacto

Requisições autenticadas com a identidade de cliente errada — grave em sistemas multi-inquilino que usam um certificado por cliente.

Correção e mitigação

Atualizar. Paliativo: usar um `https.Agent` separado por identidade de cliente.

4.5 CVE-2026-58040 — reuso de sessão TLS pula hostname

CVE-2026-58040	GRAVIDADE MÉDIA
Título oficial	HTTPS Agent session reuse can skip hostname verification
Componente	https (Agent)
Linhas afetadas	26.x, 24.x, 22.x
Corrigido em	22.23.2 · 24.18.1 · 26.5.1
Relator / correção	vnyuh / mcollina

O que identifica

Correção incompleta da CVE-2026-48934 (junho): o reuso de sessão TLS no HTTPS Agent ainda podia pular a verificação de hostname quando requisições usavam políticas de identidade diferentes (ex.: `checkServerIdentity` ou `servername` distintos).

Impacto

Conexão aceita sem verificar a identidade do servidor, abrindo espaço para man-in-the-middle.

Correção e mitigação

Atualizar. Paliativo: Agents separados por política de verificação.

4.6 CVE-2026-58041 — node:sqlite repete escritas

CVE-2026-58041	GRAVIDADE MÉDIA
Título oficial	node:sqlite SQLTagStore iterator replay can re-execute writes
Componente	node:sqlite
Linhas afetadas	26.x, 24.x
Corrigido em	22.23.2 · 24.18.1 · 26.5.1
Relator / correção	cantina-security / mcollina

O que identifica

Um iterador antigo criado via `DatabaseSync#createTagStore()` continuava executando a instrução preparada em cache depois que ela foi resetada e recebeu novos parâmetros. O `SQLTagStore` chamava `sqlite3_reset()` diretamente, contornando o mecanismo de invalidação de iteradores.

Impacto

Instruções de escrita (INSERT/UPDATE/DELETE) reexecutadas inesperadamente — corrupção de dados de integridade.

Correção e mitigação

Atualizar. Paliativo: não reutilizar iteradores do SQLTagStore depois de reexecutar a mesma consulta.

4.7 CVE-2026-58042 — dns.resolveAny() aborta o processo

CVE-2026-58042	GRAVIDADE MÉDIA
Título oficial	dns.resolveAny() can abort on DNS responses with many A records
Componente	dns
Linhas afetadas	26.x, 24.x, 22.x
Corrigido em	22.23.2 · 24.18.1 · 26.5.1
Relator / correção	cantina-security / RafaelGSS

O que identifica

`dns.resolveAny()` derruba o processo (abort, não exceção capturável) quando a resposta DNS tem mais de 256 registros A.

Impacto

Quem controla o DNS do nome consultado derruba a aplicação; repetido, vira DoS.

Correção e mitigação

Atualizar. Paliativo: preferir `dns.resolve4()`/`resolve6()` a `resolveAny()`.

4.8 CVE-2026-58045 — zlib síncrono quebra com tamanho falsificado

CVE-2026-58045	GRAVIDADE MÉDIA
Título oficial	node:zlib sync APIs can crash on spoofed TypedArray length
Componente	zlib
Linhas afetadas	26.x, 24.x, 22.x
Corrigido em	22.23.2 · 24.18.1 · 26.5.1
Relator / correção	byvini / RafaelGSS

O que identifica

Um TypedArray com `byteLength` falsificado (por exemplo via Proxy ou subclasse) dispara uma asserção nativa nas APIs síncronas do zlib (`gunzipSync`, `inflateSync` etc.).

Impacto

Crash do processo (DoS). Exige que a aplicação passe objetos construídos pelo atacante — mais relevante em ambientes que executam código de terceiros.

Correção e mitigação

Atualizar.

4.9 CVEs de gravidade baixa de julho

CVE	Título oficial	O que identifica
CVE-2026-56847	Permission Model allows trace events to write outside the allowlist	`trace_events.createTracing().enable()` grava logs de rastreamento fora dos caminhos de `--allow-fs-write`. Relator 0xoroot; correção RafaelGSS.
CVE-2026-58039	Permission Model allows process reports to write outside the allowlist	`process.report` escreve e **sobrescreve** arquivos fora da allowlist de escrita. Relator sinan-polat; correção RafaelGSS.
CVE-2026-58044	HTTP parser header truncation can enable request smuggling	Ver detalhamento abaixo. Relator yushengchen; correção mcollina.

Detalhe da CVE-2026-58044 (request smuggling)

O Node.js omite de `req.headers`, `req.rawHeaders` e `req.headersDistinct` os cabeçalhos que passam de `maxHeadersCount`/`maxHeaderPairs`, mas continua usando-os internamente para delimitar a mensagem. Um `Content-Length` escondido depois do limite some da visão da aplicação, enquanto o corpo ainda é entregue.

Um **proxy escrito em Node.js** que reconstrói os cabeçalhos a partir de `IncomingMessage` e repassa o corpo original para uma conexão reaproveitada com o backend envia ao backend uma requisição sem Content-Length mas com corpo — o backend interpreta o corpo como uma **segunda requisição**. Mitigação além do patch: não reconstruir cabeçalhos de enquadramento manualmente em proxies; usar bibliotecas de proxy mantidas.

5. Lançamento de 18/06/2026

Versões corrigidas: **22.23.0, 24.17.0 e 26.3.1**. Doze CVEs (2 altas, 6 médias, 4 baixas), mais llhttp 9.4.2, nghttp2 1.69.0, OpenSSL 3.5.7 e undici (8.5.0 / 7.28.0 / 6.27.0).

5.1 CVE-2026-48933 — WebCrypto AES: integer overflow

CVE-2026-48933	GRAVIDADE ALTA
Título oficial	WebCrypto AES Integer Overflow → Remote Process Abort
Componente	WebCrypto (crypto.subtle)
Linhas afetadas	26.x, 24.x, 22.x
Corrigido em	22.23.0 · 24.17.0 · 26.3.1
Relator / correção	erichen / Filip Skokan (panva)

O que identifica

Um cálculo de tamanho na cifragem AES do WebCrypto estoura quando a entrada de `subtle.encrypt()` é múltipla de 2 GiB, e o processo é abortado.

Impacto

Negação de serviço em qualquer caminho que cifre dados de tamanho influenciado pelo atacante.

Correção e mitigação

Atualizar. Paliativo: limitar o tamanho de dados aceitos antes de cifrar (uploads, streams).

5.2 CVE-2026-48618 — ponto Unicode burla curinga TLS

CVE-2026-48618	GRAVIDADE ALTA
Título oficial	Unicode dot separator → TLS wildcard-depth authentication bypass
Componente	tls (verificação de hostname)
Linhas afetadas	26.x, 24.x, 22.x
Corrigido em	22.23.0 · 24.17.0 · 26.3.1
Relator / correção	tmeletlidis / Matteo Collina

O que identifica

Existem caracteres Unicode que funcionam como ponto separador de domínio (ex.: o ponto ideográfico U+3002). O resolvedor os tratava como ponto, mas o verificador de certificado não. Um certificado curinga `*.exemplo.com` — que deveria valer só para um nível — podia autenticar “a[U+3002]b.exemplo.com”, que o resolvedor entende como dois níveis.

Impacto

Burla da regra de profundidade de curingas, permitindo que um certificado valha para nomes que não deveria cobrir.

Correção e mitigação

Atualizar. Paliativo: rejeitar hosts com caracteres não ASCII antes de conectar (ou convertê-los com punycode e validar).

5.3 CVEs de gravidade média de junho

CVE	Título	O que identifica e impacto
CVE-2026-48615	Proxy credentials leaked in ERR_PROXY_TUNNEL	Quando o usuário/senha do proxy estão na URL (`http://user:senha@proxy:8080`), o erro ERR_PROXY_TUNNEL incluía as credenciais na mensagem. Elas acabam em logs e ferramentas de monitoramento. **Após atualizar, troque as senhas que possam ter vazado.** Relator nssys.
CVE-2026-48619	Unbounded memory growth in node:http2 clients via ORIGIN frames	Um servidor malicioso envia frames ORIGIN sem limite a um cliente HTTP/2, que os acumula até ficar sem memória. Relator kingsd.
CVE-2026-48937	HTTP/2 sessions don't clean up after GOAWAY	O servidor HTTP/2 continuava aceitando dados depois de enviar GOAWAY por erro de protocolo, consumindo recursos. Só linhas 22 e 24. Relator e correção Tim Perry.
CVE-2026-48928	Uppercase SNI context matching → mTLS authorization bypass	A escolha de contexto SNI diferenciava maiúsculas de minúsculas. Em servidores com vários contextos mTLS, `API.exemplo.com` caía num contexto com política de confiança diferente de `api.exemplo.com`. Relator tmeletlidis.
CVE-2026-48930	Embedded-NUL hostnames → silent authority rebinding	Hostnames com byte NUL eram truncados nas bindings do resolvedor; a conexão ia para uma autoridade diferente da solicitada, sem erro. Mesmo padrão da 3.2. Relator tmeletlidis.
CVE-2026-48934	TLS host identity verification bypass via session reuse	Reusar uma sessão TLS com outro `servername` pulava a validação de certificado. A correção foi incompleta e gerou a CVE-2026-58040 (julho). Relator 3d7omb.

5.4 CVEs de gravidade baixa de junho

CVE	Título	O que identifica
CVE-2026-48617	Permission Model bypass via process.report.writeReport()	O caminho de saída do relatório não era validado contra o Permission Model. Relator suul.
CVE-2026-48935	Permission Model bypass via FileHandle.utimes()	A versão Promise de `utimes()` alterava datas de arquivos em caminhos só de leitura. Relator muhammaddaffa.
CVE-2026-48936	Unix domain socket server bypasses --permission network restrictions	Servidor em socket Unix podia ser criado sem `--allow-net` (correção incompleta da CVE-2026-21636). Só linha 26. Relator Vitaly Simonovich.
CVE-2026-48931	HTTP response queue poisoning via TOCTOU race in http.Agent	Condição de corrida em que o cliente aceitava uma resposta enviada antes da requisição. Retornou como CVE-2026-105481 (outubro). Relator yushengchen.

6. Padrões que se repetem

Olhando as 33 CVEs juntas, alguns padrões ajudam a entender onde estão os riscos do Node.js em 2026:

- **Normalização inconsistente de hostnames:** CVE-2026-48618 (ponto Unicode), 48928 (maiúsculas), 48930 e 105482 (NUL), 105483 (fullwidth), 106069 e 106072 (IP não canônico). Sempre que duas partes do runtime interpretam o mesmo nome de formas diferentes, surge um bypass. Para quem desenvolve: valide e normalize o destino **uma vez**, antes de usar.
- **Correções incompletas e regressões:** 48934 → 58040; 48931 → 105481; 21715 → 106073; 21636 → 48936; 105483 é regressão de uma correção de normalização de IP. Vale acompanhar os lançamentos seguintes a qualquer correção importante.
- **Permission Model ainda imaturo:** 8 CVEs em quatro meses (10 contando março). É útil como camada extra, não como sandbox.
- **HTTP/2 e keep-alive:** esgotamento de memória e confusão de respostas aparecem em todos os lançamentos. Terminar HTTP/2 num proxy reduz a superfície.
- **Dependências nativas embutidas** (Brotli, nghttp2, llhttp, c-ares, OpenSSL, undici) são a origem das falhas mais graves — e a correção chega pelo binário do Node.js, não pelo `npm update`.

7. Recomendações práticas

Prioridade imediata

- Inventariar onde roda Node.js: servidores, containers (imagem base), funções serverless, ferramentas internas, apps Electron e produtos de terceiros que embutem o runtime.
- Atualizar para 22.23.4 / 24.22.1 / 26.12.1 com nvm, instalador oficial, gerenciador de pacotes ou nova imagem base (`docker build --pull`).
- **Reiniciar** todos os processos (pm2, systemd, Kubernetes rollout). Reconstruir SEAs, snapshots, imagens Lambda e containers.
- Migrar o que estiver em Node.js 20 ou 25 (EOL) para 22 ou 24.
- Se após a atualização surgirem erros de certificado em integrações, verificar se a cadeia do servidor usa as intermediárias eMudhra bloqueadas.

Enquanto a atualização não sai (paliativos não oficiais)

- Brotli: no proxy/WAF, rejeitar `Content-Encoding: br` em requisições de entrada e remover `br` do `Accept-Encoding` de saída onde possível.
- TLS: validar destinos informados pelo usuário (só ASCII, `net.isIP()` para IPs, sem caracteres de controle). Nunca desativar `rejectUnauthorized`.
- HTTP/2: terminar no proxy reverso; limitar memória do container com reinício automático.
- Keep-alive: desativar para destinos não confiáveis; usar Agents separados por identidade mTLS.
- Rotacionar credenciais de proxy que estavam em URLs (CVE-2026-48615) e tokens gerados por SEAs/snapshots (CVE-2026-106074).

Detecção (Blue Team)

- Alertar sobre reinícios inesperados de processos Node (pm2 restarts, CrashLoopBackOff, `SIGABRT`/`SIGSEGV` nos logs do systemd).
- Monitorar processos filhos inesperados do usuário do serviço Node.js e conexões de saída novas — sinais pós-exploração da Brotli RCE.
- Observar respostas com `Content-Encoding: br` de origens incomuns e picos de memória em serviços HTTP/2.

- Lembrar que `npm audit` e Dependabot não cobrem o runtime: inclua a versão do Node.js no inventário de ativos e no scanner de vulnerabilidades (Trivy, Grype etc. leem a imagem base).

Apêndice A — Lançamento de 24/03/2026 (resumo)

Versões corrigidas: 20.20.2, 22.22.2, 24.14.1 e 25.8.2 (último lançamento de segurança que incluiu as linhas 20 e 25). undici 6.24.1 e 7.24.4.

CVE	Grav.	Descrição resumida	Linhas
Correção incompleta da CVE-2026-21637	Alta	loadSNI() sem try/catch: exceção em SNICallback derruba o processo	20, 22, 24, 25
CVE-2026-21710	Alta	Cabeçalho __proto__ em req.headersDistinct lança TypeError não capturável (DoS)	20, 22, 24, 25
CVE-2026-21711	Média	Permission Model: bind/listen em socket Unix sem --allow-net	25
CVE-2026-21712	Média	Asserção em node_url.cc com IDN malformado em url.format() (crash)	24, 25
CVE-2026-21713	Média	Comparação de HMAC não constante no tempo (canal lateral)	20, 22, 24, 25
CVE-2026-21714	Média	HTTP/2: WINDOW_UPDATE no stream 0 vaza Http2Session	20, 22, 24, 25
CVE-2026-21717	Média	HashDoS no V8 com strings numéricas (ex.: JSON.parse)	20, 22, 24, 25
CVE-2026-21715	Baixa	Permission Model: fs.realpathSync.native sem checagem de leitura	20, 22, 24, 25
CVE-2026-21716	Baixa	Permission Model: FileHandle.chmod/chown sem checagem de escrita	20, 22, 24, 25

Fontes de pesquisa

Fontes consultadas em 22/10/2026. Os avisos em nodejs.org são a fonte primária; detalhes atribuídos a terceiros estão indicados no texto.

Fontes oficiais do Node.js

[1] Wednesday, October 21, 2026 Security Releases
https://nodejs.org/en/blog/vulnerability/october-2026-security-releases

[2] Wednesday, July 29, 2026 Security Releases
https://nodejs.org/en/blog/vulnerability/july-2026-security-releases

[3] Thursday, June 18, 2026 Security Releases
https://nodejs.org/en/blog/vulnerability/june-2026-security-releases

[4] Tuesday, March 24, 2026 Security Releases
https://nodejs.org/en/blog/vulnerability/march-2026-security-releases

[5] Notas de versão Node.js v24.22.1 (commits das correções de outubro)
https://nodejs.org/en/blog/release/v24.22.1

[6] Índice de avisos de vulnerabilidade do Node.js
https://nodejs.org/en/blog/vulnerability

[7] Política de segurança do Node.js
https://nodejs.org/en/security/

[8] Calendário de versões (Release Schedule)
https://github.com/nodejs/release#release-schedule

Imprensa e análises de terceiros

[9] Linux Compatible — Node.js October 2026 Security Update: 10 Vulnerabilities Patched
https://www.linuxcompatible.org/story/nodejs-october-2026-security-update-10-vulnerabilities-patched-across-3-release-lines

[10] explainx.ai — Node.js Security Update Oct 2026: 10 Fixes, Update Now
https://explainx.ai/blog/nodejs-security-release-october-2026-brotli-rce-tls-hostname-bypass-emudhra-2026

[11] GBHackers — Node.js Patches 10 Security Vulnerabilities, Including High-Severity RCE Flaw
https://gbhackers.com/node-js-patches-10-security-vulnerabilities/

[12] Red Tiger Security — Node.js October 2026 Security Release: Where It Runs in OT
https://www.redtigersecurity.com/advisory/nodejs-october-2026-security-release

[13] Digital Applied — Node.js July Security Releases: What Actually Shipped
https://www.digitalapplied.com/blog/nodejs-july-2026-security-releases-shipped

[14] HeroDevs — March 2026 Node.js Security Release: Eight CVEs Patched
https://www.herodevs.com/blog-posts/march-2026-node-js-security-release-eight-cves-patched-including-two-high-severity-process-crashes

[15] Endor Labs — Eight for One: Multiple Vulnerabilities Fixed in the Node.js Runtime
https://www.endorlabs.com/learn/eight-for-one-multiple-vulnerabilities-fixed-in-the-node-js-runtime